

Reporte de Vulnerabilidad

Archivo: malicioso.php

Código Analizado:

```
<?php echo 'ataque'; ?>
```

Análisis: ``html
Vulnerabilidades de Seguridad

Cross-Site Scripting (XSS)

Línea aproximada: <?php echo 'ataque'; ?>

Descripción: Aunque el código parece inofensivo, demuestra la capacidad de imprimir una cadena en la página. En un escenario real, esta línea podría usarse para imprimir datos controlados por el usuario sin la validación o el escapado adecuados. Si un atacante lograra inyectar código malicioso (como JavaScript) en la variable que se imprime, este código se ejecutaría en el navegador del usuario, lo que permitiría el robo de cookies, el redireccionamiento a sitios maliciosos o la modificación del contenido de la página.

Mitigación:

- **Escapado de salida:** Utilizar funciones de escapado específicas del contexto para evitar que el código se interprete como HTML, JavaScript u otro tipo de código ejecutable. Por ejemplo, en PHP, se podría usar `htmlspecialchars()` para escapar caracteres especiales de HTML.
- **Validación de entrada:** Validar todos los datos proporcionados por el usuario para asegurar que cumplen con el formato y el tipo esperados. Rechazar datos que no cumplen con los criterios de validación.
- **Codificación:** Dependiendo de cómo se use la salida (p.ej., como atributo HTML), utilice la codificación adecuada.

Métricas de Calidad del Código

Análisis

Complejidad: El código es muy simple, por lo tanto, la complejidad es baja.

Duplicación: Dada la simplicidad del fragmento, la duplicación no es un problema.

Legibilidad: El código es legible, ya que es muy corto y directo.

Acoplamiento: El acoplamiento es mínimo, ya que no hay dependencias externas evidentes en este fragmento. Sin embargo, en un contexto real, el acoplamiento dependería de cómo se integre este código en el resto de la aplicación.

Mejoras: Aunque el código es simple, podría mejorarse al incluir comentarios que expliquen el propósito de la impresión de la cadena y al implementar el escapado de salida (aunque en este ejemplo no se impriman datos del usuario, demostrar las buenas prácticas).

Solución Propuesta

Código con escapado de salida

Para evitar el XSS, se aplica la función `htmlspecialchars()` a la salida.

```
<?php echo htmlspecialchars('ataque', ENT_QUOTES, 'UTF-8'); ?>
```

Explicación:

- `htmlspecialchars()` convierte caracteres especiales en entidades HTML.
- `ENT_QUOTES` asegura que tanto las comillas simples como las dobles se escapen.
- UTF-8 especifica la codificación de caracteres.

...